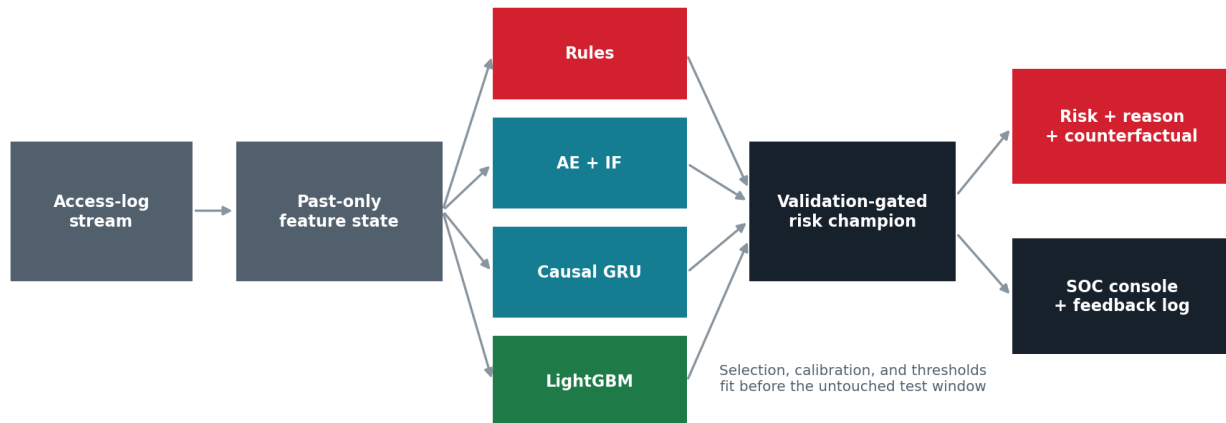


SentinelUEBA

AI-Powered Behavioural Anomaly Detection for Cybersecurity

Honeywell Technologies Campus Connect 2026 | Problem 4 | Induj Gupta



Untouched chronological test: PR-AUC 0.994 (95% entity-bootstrap CI 0.985-0.998), ROC-AUC 0.999. At a threshold fixed on validation, precision is 100.0%, recall is 46.7%, and benign false-positive rate is 0.000%.

This report treats synthetic evaluation honestly: metrics demonstrate engineering behaviour under documented simulation assumptions, not a production guarantee. Reproducible data generation, source hashes, model weights, fixed thresholds, and an executable inference replay are included.

Submission build: SentinelUEBA 2.1 | Generated 2026-07-25 | Seed 42

1. Executive Summary

- SentinelUEBA learns normal access behaviour for users, service accounts, and industrial edge devices, then ranks suspicious events for a constrained SOC alert budget. It combines deterministic security evidence, normal-only autoencoder and Isolation Forest models, a causal GRU sequence model, and a LightGBM attack classifier. A validation-gated champion selector uses fusion only when it improves precision-recall ranking.
- **Past-only inference:** true rolling per-entity/per-IP state, causal home/device baselines, causal session prefixes, and training-reference score CDFs.
 - **Cold start:** explicit role one-hot features plus peer-relative hour, resource-rarity, and byte-volume priors that fade as entity history grows.
 - **Concept drift:** Page-Hinkley detection, protected rolling baselines, auditable baseline epochs, and attack-rule protection against profile poisoning.
 - **Explainability:** quantified rule evidence, TreeSHAP drivers, counterfactual conditions, MITRE ATT&CK; mapping, and entity timelines.
 - **Operational loop:** fixed validation thresholds, persistent analyst dispositions, next-refresh label overrides, saved models, and replay inference.

Why it matters to Honeywell

The challenge asks specifically for behavioural detection, low false positives, explainability, scalability, anomaly classification, and system design [1]. Honeywell's 2025 cyber research analysed more than 250 billion logs and calls out AI-assisted security analysis for faster, smarter decisions [2]. Honeywell Cyber Insights describes a granular adaptive baseline for OT anomaly detection and false-positive reduction [3], while Honeywell Cyber Proactive Defense uses behavioural analytics to establish a system baseline and surface actionable insights [4]. SentinelUEBA is a student prototype aligned to those product principles, not a claim of equivalence.

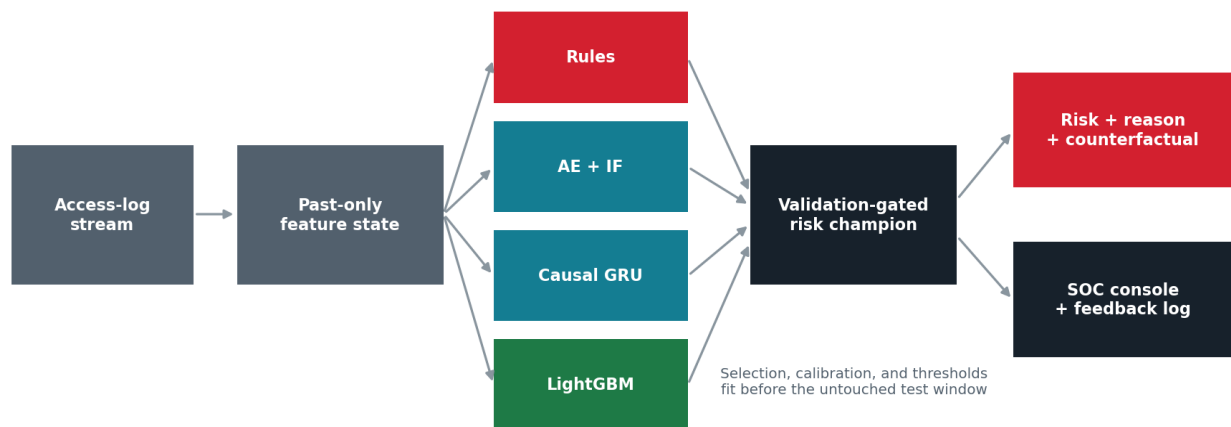
2. Data and Threat Model

The deterministic generator creates 330,190 events for 400 entities over 45 days. The anomaly prevalence is 2.02%. Entity profiles include role, home geography, working hours, resources, IP block, protocol, device fingerprint, activity rate, and authentication-failure rate. Ground truth is retained only for supervised fitting and evaluation; inference code does not require labels.

Behaviour	Simulation signal	Primary evidence
Brute force	Rapid repeated authentication attempts	Entity burst + failure rate
Impossible travel	Distant successful login after short gap	Geo-velocity physics
Credential stuffing	One/few IPs fan out across accounts	Causal IP fan-out + failures
Lateral movement	Unusual resource sequence and breadth	Causal GRU + prefix novelty
Device spoofing	OS/MAC fingerprint changes	Prior fingerprint mode
Low-and-slow exfiltration	Off-hours elevated reads over days	24h volume + adaptive z-score

Benign stress cases include travel, noise in working hours, changing resources, and gradual insider drift. Remaining realism limits are listed in Section 9.

3. Architecture and Model Choices



Layer	Role	Why
Rules	High-precision physical/rate evidence	Immediate reasons; no labels required
Dense AE	Normal manifold reconstruction	Detects off-profile unknown behaviour
Isolation Forest	Distribution-light anomaly channel	Robust complement to reconstruction
Causal GRU AE	Session-prefix dynamics	Sequential signal without future events
LightGBM	Attack-type probability + SHAP	Strong, inspectable tabular classifier
Risk champion	Validation-selected and calibrated score	Prevents weaker fusion from degrading ranking

The operational strategy selected before test was **classifier**. Candidate validation scores are reported in the run artifact; the selector prefers the simpler candidate when PR-AUC differs by less than 0.001.

Causal feature state

For each event, state is read first and updated second. IP fan-out and failure rate use true one-hour dequeues; burst counts use five-minute dequeues; device and home-city modes use prior observations; resource novelty uses prior entity and role counters; session features describe only the prefix ending at the event. The GRU receives that same prefix and scores only its final position. Autoencoder, Isolation Forest, and GRU outputs are mapped through empirical CDFs fitted on normal training events.

4. Evaluation Protocol

The evaluation is chronological and has four functional stages. One-hour purge gaps reduce leakage from bursts or campaigns crossing boundaries.

Window	Purpose	Can influence final test score?
Train (earliest 50%)	Scaler, normal baselines, GRU, classifier	Model parameters only
Validation A	Fit logistic stacker	Fusion parameters only
Validation B	Select champion, calibrate probability, fix thresholds	Policy only
Final test (latest 35%)	One-time reporting	No selection or fitting

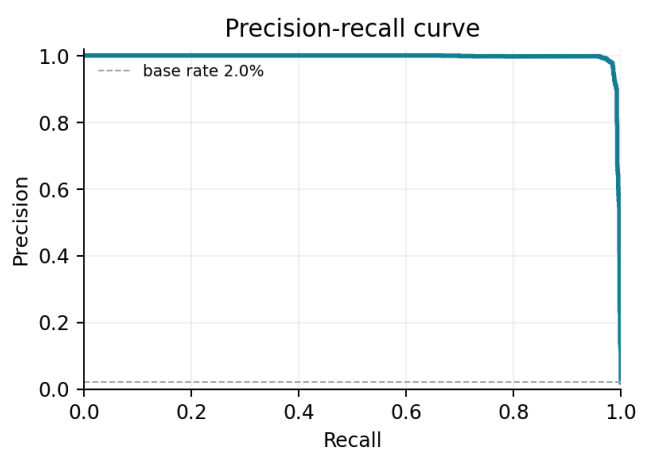
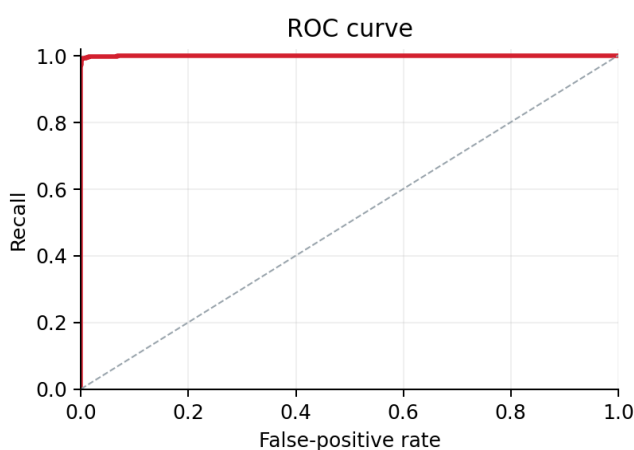
Integrity controls. 818 boundary events are excluded; all score normalisation references training only; alert thresholds come from the final calibration segment; rule overrides are enabled only when they improve validation macro-F1; test is not used for selection. The test contains 115,360 events.

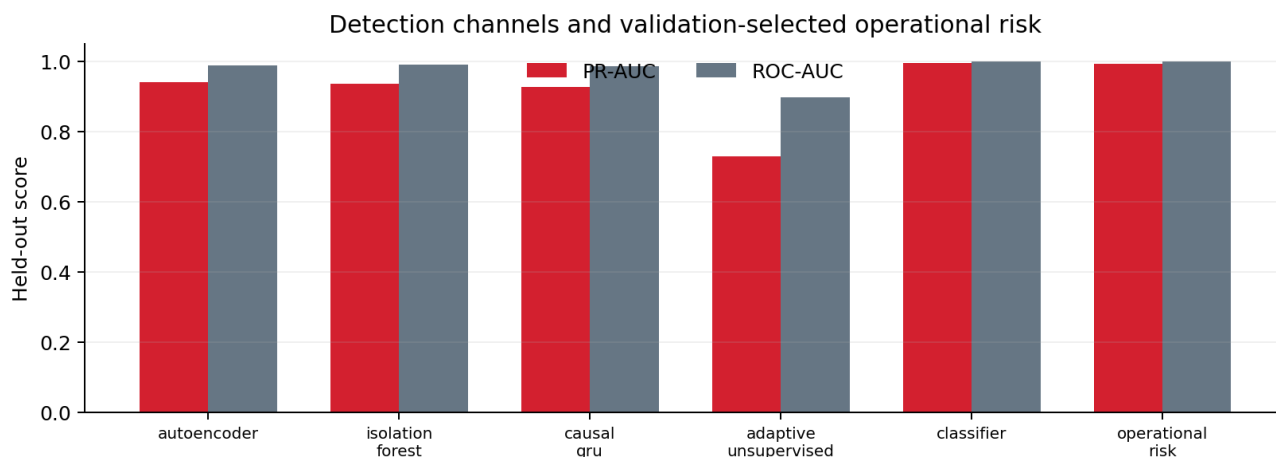
Metrics

- PR-AUC is primary because attacks are rare; ROC-AUC is secondary.
- Precision, recall, and benign false-positive rate are measured at validation-fitted analyst-budget thresholds.
- Attack typing uses per-class precision/recall/F1 and attack-only macro-F1.
- 95% intervals use an entity-cluster bootstrap rather than treating dependent events as independent.
- Cold-start and benign-drift subsets are measured separately.

5. Detection Results

Metric	Untouched test result
PR-AUC	0.9943 (95% CI 0.9851-0.9984)
ROC-AUC	0.9994 (95% CI 0.9985-0.9999)
Brier score	0.0007
Expected calibration error	0.0006
Attack-type macro-F1	0.9469





Fixed operating points

Policy	Validation threshold	Test alert rate	Precision	Recall	FP rate
top 0.5%	99.19	0.49%	1.000	0.244	0.0000
top 1%	99.19	0.93%	1.000	0.467	0.0000
top 2%	0.00	2.68%	0.737	0.993	0.0072
top 5%	0.00	5.85%	0.340	0.997	0.0394

The realised test alert rate is allowed to differ from the named policy: that difference is evidence the threshold was fixed before seeing test, rather than re-ranked on the test distribution.

Coverage vs. precision trade-off (read this alongside the headline). The top-1% policy is precision-first: overall recall at that budget is only 46.7%, because with a 2.0% base rate a 1% budget cannot flag even half the attacks, and it prioritises high-volume families. Per-attack recall at the top-1% threshold: brute force 56%, impossible travel 0%, credential stuffing 42%, lateral movement 20%, device spoofing 0%, low and slow exfiltration 5%. Low-volume types (impossible travel, device spoofing) fall below the strict cut and are recovered at **top-2% — the recommended coverage operating point (99.3% recall at 73.7% precision)**. Top-1% is the zero-false-positive policy, not the maximum-coverage policy.

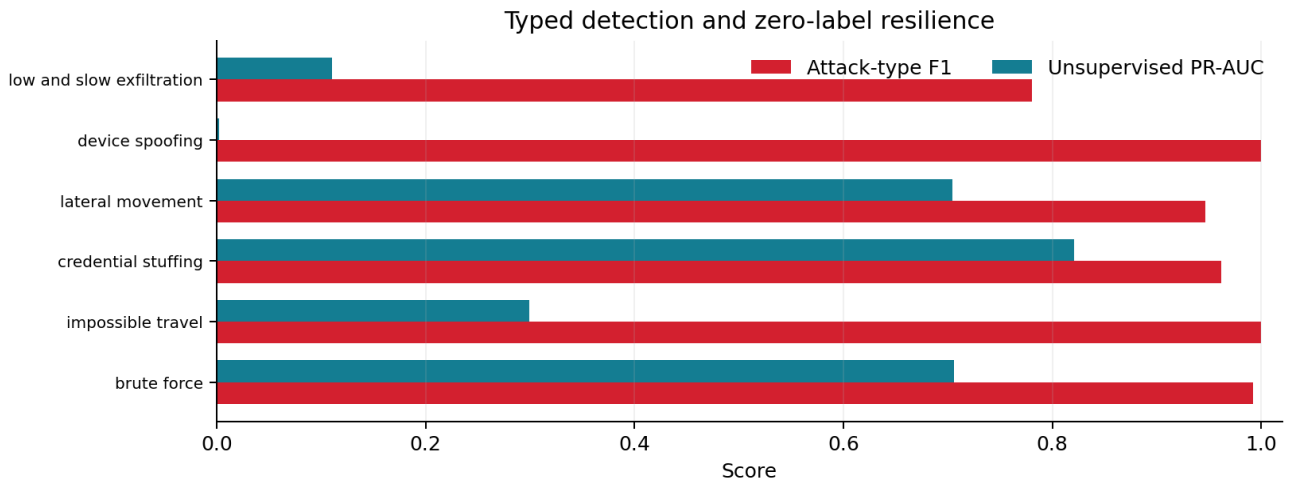
Cross-seed generalization

The frozen seed-42 model bundle and its validation-fitted thresholds were applied unchanged to 5 independently generated datasets (seeds never used in training, fusion selection, or calibration). Performance is stable and benign false positives stay at zero on every seed — evidence the result is not a favourable-seed artefact and the thresholds were not tuned to the test distribution.

Metric	Mean $\pm$ Std (5 seeds)	Min / Max
ROC-AUC	0.9994 $\pm$ 0.0002	0.999 / 1.000
PR-AUC	0.9943 $\pm$ 0.0015	0.992 / 0.996
Attack macro-F1	0.9532 $\pm$ 0.0074	0.944 / 0.965
Top-1% precision	1.0000 $\pm$ 0.0000	1.000 every seed
Top-1% false positives	0.0 $\pm$ 0.0	0 every seed
Cold-start recall	0.690 $\pm$ 0.116	0.537 / 0.822 (n=227)

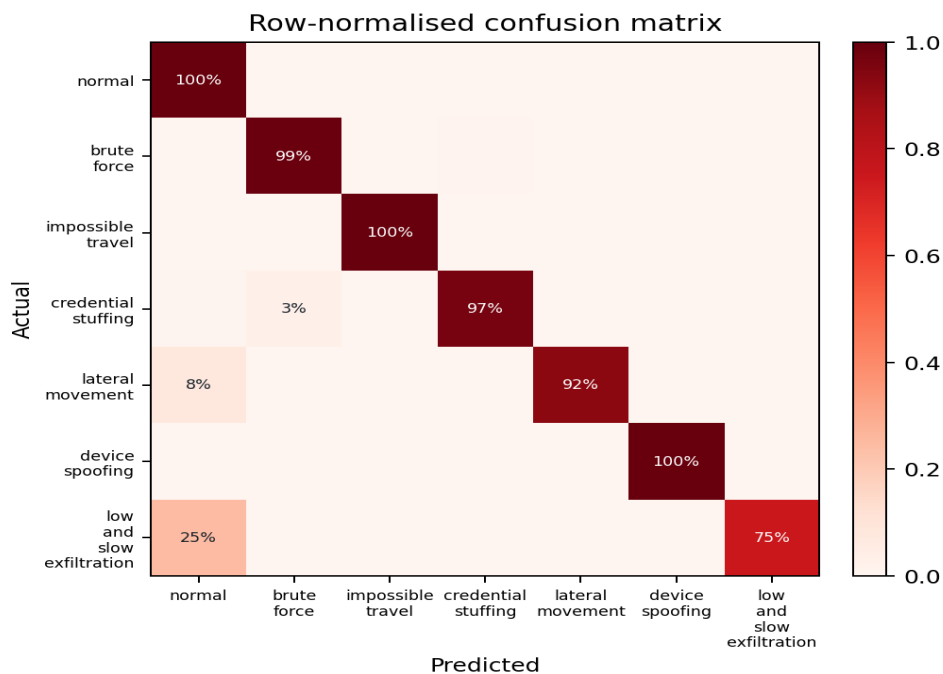
Cold-start recall is reported across seeds because a single run has too few cold-start attacks to be stable: the main run's 93.1% is on 29 attacks, whereas the multi-seed mean above is the honest figure to quote.

6. Classification and Robustness



Attack	Precision	Recall	F1	Support	Unsupervised PR-AUC
brute force	0.993	0.992	0.992	1588	0.706
impossible travel	1.000	1.000	1.000	8	0.299
credential stuffing	0.956	0.967	0.961	361	0.821
lateral movement	0.973	0.922	0.947	154	0.705
device spoofing	1.000	1.000	1.000	28	0.002
low and slow exfiltration	0.812	0.752	0.781	161	0.110

Zero-label resilience evaluates each attack against benign test events using only the adaptive unsupervised channel. It is not a claim of true unseen-family validation; it quantifies detection evidence available without attack labels.



Executed real-telemetry probe: a held-out complementarity test

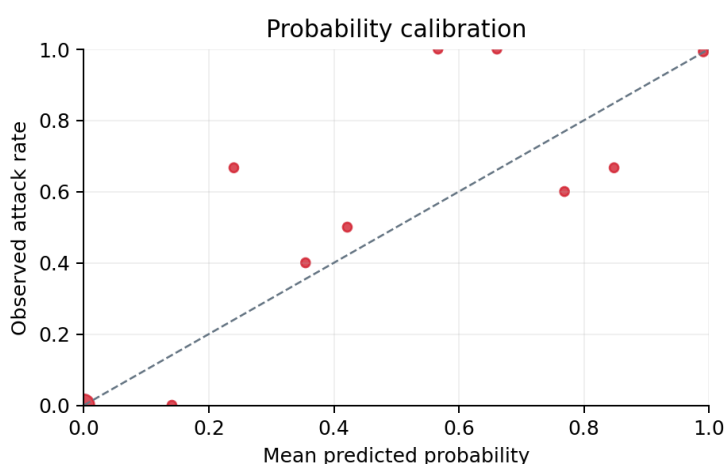
As an external boundary test (not attack validation), we ran the unsupervised behavioural detector on a real public insider-threat corpus (SPEDIA, Zenodo 15495572: 70,878 real Wazuh host events, 17 users). We used a chronological split: 42,526 events for unsupervised fitting and 28,352 later events for untouched scoring. All rarity features use prior events only. The dataset's only available label is Wazuh's **signature-defined** high-severity flag (command executions such as `/bin/nc`, which fires in-hours at ordinary volume (off-hours rate 4.9% vs 7.6% for normal traffic). The behavioural-only detector does not rank these highly (PR-AUC 0.018). We read this cautiously: it is **consistent with** — not proof of — the hypothesis that behavioural anomaly detection and signature detection are complementary, which is why SentinelUEBA is a **hybrid**. The label remains a rule proxy, so this negative-control result does not establish real-data attack performance. (Reproduce with `evaluate_spedia.py` after downloading `logs_SPEDIA.csv` from Zenodo; a red-team-labelled behavioural benchmark harness for LANL authentication logs is

7. Imbalance, Cold Start, and Drift

Challenge	Implementation	Measured result
Extreme imbalance	Normal-only unsupervised channels; balanced classifier; PR-AUC; fixed alert budget	2.02% base rate; PR-AUC 0.994
Cold start	Role priors for hour, resource rarity, and bytes; explicit cold-history weight	Single run 93.1% (n=29, unstable); quote the multi-seed mean in the cross-seed table. FP rate 0.000%
Concept drift	Page-Hinkley; protected recent baseline; baseline epochs; feedback rebaseline queue	Benign-drift FP rate 0.000%; 63 test alarms

Adaptation safety

Any high-confidence rule hit is excluded from adaptive profile updates. This reduces baseline poisoning: a burst, impossible-travel event, spoofed fingerprint, or exfiltration rule cannot teach the entity profile that the attack is normal. Page-Hinkley alarms create a new baseline epoch and a short learning window for moderate, unprotected changes.



8. Analyst Experience and Deployment

The Streamlit console hides synthetic ground truth by default. It provides a ranked queue, quantified evidence, entity timelines, channel scores, baseline epochs, fixed-threshold evaluation, cold-start/drift monitoring, and an analyst-feedback audit table.

Time	Entity	Classification	Risk	Reason
07-11 00:59	U0168	credential stuffing	100.0	[credential_stuffing] behavioural deviation driven by ip_distinct_entities_1h, bytes_z, peer_resource_rarity
07-05 00:20	U0186	low and slow exfiltration	99.9	[low_and_slow_exfiltration] exfiltration pattern: 24h off-hours volume log=12.2, peer z=3.4 would be benign in work hours at normal data volume
07-05 22:03	U0073	brute force	99.6	[brute_force] behavioural deviation driven by ip_fail_rate_1h, entity_fail_rate_1h, entity_event_count_5min
07-08 13:55	U0044	lateral movement	99.2	[lateral_movement] impossible travel: 20000 km/h would be benign if geo-velocity < 900 km/h

Feedback loop

Submitting a disposition writes an append-only audit record with event, entity, model label, risk, analyst, note, and UTC time. On the next run, confirmed false positives and expected behaviour become normal training overrides; confirmed attacks can correct attack labels; expected behaviour also creates a rebaseline request. The prototype deliberately says 'next model refresh' rather than pretending the button retrains instantly.

Persisted inference

```
python -m src.inference --input access_logs.csv --output scored.parquet --policy top_1pct
```

The command loads the saved scaler, categorical vocabulary, Isolation Forest, LightGBM model, risk selector/calibrator, CDF references, PyTorch weights, approved rule overrides, and validation thresholds. The same causal feature engine is used for training replay and inference.

Measured component	Events	Throughput	Scope
Causal feature replay	10,000	10,956 events/s	Python state engine
Complete model path	20,000	19,539 events/s	AE + IF + causal GRU + LightGBM + risk

Benchmark host: Intel64 Family 6 Model 183 Stepping 1, GenuineIntel CPU; single-thread model settings; no GPU. These are batch-replay measurements, not distributed production-load results.

9. Limitations and Next Steps

- **Current:** Primary evaluation data is synthetic because access logs with attack ground truth are privacy restricted.
- **Current:** Attack patterns are simulations, so absolute metrics should not be treated as production guarantees.
- **Current:** The prototype is a chronological replay, not a deployed Kafka service.
- **Current:** Analyst feedback is applied on the next model refresh, not instantly.
- **Next validation:** train on one generator family and test on parameter-shifted campaigns plus public identity/authentication logs.
- **Next architecture:** Kafka-compatible state checkpointing, model registry, shadow deployment, latency SLOs, and drift-triggered approval workflow.
- **Next detection:** temporal entity-resource graph channel for lateral movement, evaluated as an ablation rather than added by default.
- **Next security:** adversarial profile-poisoning tests, compromised service-account campaigns, and red-team review of reason-code leakage.

Reproducibility

The archive includes source, tests, generated report/deck, complete scored test replay, model bundle and weights, run_manifest.json with dependency versions and SHA-256 hashes, and SUBMISSION_MANIFEST.json with archive checksums. The full dataset is regenerated from seed 42.

References

- [1] Honeywell Technologies Campus Connect 2026, AI-Powered Behavioral Anomaly Detection for Cybersecurity. <https://honeywelltechnologiescampusconnect.mycareernet.co/>
- [2] Honeywell, 2025 Cyber Threat Report press release, 4 Jun 2025. <https://www.honeywell.com/us/en/news/press-releases/2025/06/ransomware-attacks-targeting-industrial-operators-surge-46-percent-in-one-quarter-honeywell-report-finds>
- [3] Honeywell, Cyber Insights product page. <https://process.honeywell.com/us/en/products/process-automation/cyber-suite/cyber-insights>
- [4] Honeywell, AI-enabled industrial cybersecurity suite, 9 Jun 2025. <https://www.honeywell.com/us/en/news/press-releases/2025/06/honeywell-drives-industrial-transition-from-automation-to-autonomy-with-new-ai-enabled-digital-suite>
- [5] MITRE ATT&CK; Brute Force T1110, Credential Stuffing T1110.004, Remote Services T1021, Valid Accounts T1078, Masquerading T1036, and Data Transfer Size Limits T1030. <https://attack.mitre.org/>
- [6] L. Antwarg, R. M. Miller, B. Shapira, and L. Rokach, 'Explaining anomalies detected by autoencoders using Shapley Additive Explanations,' Expert Systems with Applications 186 (2021), 115736. <https://doi.org/10.1016/j.eswa.2021.115736>